

RAPPORT D'ANALYSE DE SÉCURITÉ API

Projet : FUTURE_CS_03 | Future Interns Cyber Security

1. Informations Générales

- **Nom du Stagiaire** : MAWOUÉNA LOUMON FÉLIX AYI
- **ID Stagiaire (CIN)** : FIT/JAN26/CS5914
- **Domaine** : Cyber Sécurité
- **Date** : 11 Février 2026

2. Objectif de la mission

L'objectif de cette tâche est de tester la sécurité d'un point de terminaison (endpoint) d'une API publique et d'identifier les risques liés à l'exposition des données.

3. Méthodologie

- **Outil** : Navigateur Web.
- **Cible** : JSONPlaceholder API (/users).
- **Méthode** : Analyse de la réponse HTTP et vérification des mécanismes d'authentification.

4. Preuve Technique (Capture d'écran)

```
[
{
  "id": 1,
  "name": "Leanne Graham",
  "username": "Bret",
  "email": "Sincere@april.biz",
  "address": {
    "street": "Kulas Light",
    "suite": "Apt. 556",
    "city": "Gwenborough",
    "zipcode": "92998-3874",
    "geo": {
      "lat": "-37.3159",
      "lng": "81.1496"
    }
  },
  "phone": "1-770-736-8031 x56442",
  "website": "hildegard.org",
  "company": {
    "name": "Romaguera-Crona",
    "catchPhrase": "Multi-layered client-server neural-net",
    "bs": "harness real-time e-markets"
  }
},
{
  "id": 2,
  "name": "Ervin Howell",
  "username": "Antonette",
  "email": "Shanna@melissa.tv",
  "address": {
    "street": "Victor Plains",
    "suite": "Suite 879",
    "city": "Wisokyburgh",
    "zipcode": "90566-7771",
    "geo": {
      "lat": "-43.9509",
      "lng": "-34.4618"
    }
  },
  "phone": "010-692-6593 x09125",
  "website": "anastasia.net",
  "company": {
    "name": "Deckow-Crist",
    "catchPhrase": "Proactive didactic contingency",
    "bs": "synergize scalable supply-chains"
  }
}
]
```

5. Analyse des Résultats

L'analyse de la capture d'écran ci-dessus révèle les points suivants :

1. **Exposition de données** : L'API retourne des informations personnelles (PII) telles que les emails, les adresses physiques et les numéros de téléphone.
2. **Format des données** : Les données sont structurées en format JSON, facilitant l'extraction automatique par un script malveillant.
3. **Absence d'authentification** : Aucune clé API (API Key) ou jeton (Bearer Token) n'a été demandé pour accéder à ces informations.

6. Recommandations de Sécurité

Pour sécuriser cette interface, il est recommandé de :

- **Implémenter OAuth2/JWT** : Restreindre l'accès aux seuls utilisateurs authentifiés.
- **Appliquer le principe du "Least Privilege"** : Ne retourner que les champs strictement nécessaires à l'application.
- **Activer le Rate Limiting** : Empêcher un utilisateur de faire des milliers de requêtes par minute pour voler toute la base de données.